

9 Yêu cầu cơ bản cho hệ thống thông tin cấp độ 5

9.1 Yêu cầu quản lý

9.1.1 Thiết lập chính sách an toàn thông tin

9.1.1.1 Chính sách an toàn thông tin

Xây dựng chính sách an toàn thông tin, bao gồm:

a) Xác định các mục tiêu, nguyên tắc bảo đảm an toàn thông tin;

b) Xác định trách nhiệm của đơn vị chuyên trách về an toàn thông tin, các cán bộ làm về an toàn thông tin và các đối tượng thuộc phạm vi điều chỉnh của chính sách an toàn thông tin;

c) Xác định phạm vi chính sách an toàn thông tin bao gồm:

- Phạm vi quản lý về vật lý và logic của tổ chức;
- Các ứng dụng, dịch vụ hệ thống cung cấp;
- Nguồn nhân lực bảo đảm an toàn thông tin.

d) Xây dựng chính sách an toàn thông tin bao gồm:

- Quản lý an toàn mạng;
- Quản lý an toàn máy chủ và ứng dụng;
- Quản lý an toàn dữ liệu;
- Quản lý an toàn thiết bị đầu cuối;
- Quản lý phòng chống phần mềm độc hại;
- Quản lý điểm yếu an toàn thông tin;
- Quản lý giám sát an toàn hệ thống thông tin;
- Quản lý sự cố an toàn thông tin;
- Quản lý an toàn người sử dụng đầu cuối.

9.1.1.2 Xây dựng và công bố

a) Chính sách được tổ chức/bộ phận được ủy quyền thông qua trước khi công bố áp dụng;

b) Chính sách được quản lý theo từng phiên bản khi có sự thay đổi, cập nhật;

c) Chính sách được công bố trước khi áp dụng;

d) Tổ chức tuyên truyền, phổ biến nội dung chính sách quản lý an toàn thông tin cho toàn bộ cán bộ trong tổ chức.

9.1.1.3 Rà soát, sửa đổi

a) Định kỳ 06 tháng hoặc khi có thay đổi chính sách an toàn thông tin kiểm tra lại tính phù hợp và thực hiện rà soát, cập nhật, bổ sung;

b) Có hồ sơ lưu lại thông tin phản hồi của đối tượng áp dụng chính sách trong quá trình triển khai, áp dụng chính sách an toàn thông tin.

9.1.2 Tổ chức bảo đảm an toàn thông tin

9.1.2.1 Đơn vị chuyên trách về an toàn thông tin

- a) Thành lập hoặc chỉ định đơn vị chuyên trách về an toàn thông tin trong tổ chức;
- b) Phân định vai trò, trách nhiệm, cơ chế phối hợp của các bộ phận, cán bộ trong đơn vị chuyên trách về an toàn thông tin;
- c) Chỉ định bộ phận chuyên trách trong đơn vị chuyên trách về an toàn thông tin có trách nhiệm xây dựng và thực thi chính sách an toàn thông tin;
- d) Bố trí cán bộ ở vị trí quan trọng phải là cán bộ chuyên trách;
- đ) Bố trí tối thiểu 02 cán bộ theo mỗi mảng công việc cần quản lý, thực thi.

9.1.2.2 Phối hợp với những cơ quan/tổ chức có thẩm quyền

- a) Có đầu mối liên hệ, phối hợp với các cơ quan, tổ chức có thẩm quyền quản lý về an toàn thông tin;
- b) Có đầu mối liên hệ, phối hợp với các cơ quan, tổ chức trong công tác hỗ trợ điều phối xử lý sự cố an toàn thông tin;
- c) Tham gia các hoạt động, công tác bảo đảm an toàn thông tin khi có yêu cầu của tổ chức có thẩm quyền.

9.1.3 Bảo đảm nguồn nhân lực

9.1.3.1 Tuyển dụng

- a) Cán bộ được tuyển dụng vào vị trí làm về an toàn thông tin có trình độ, chuyên ngành về lĩnh vực công nghệ thông tin, an toàn thông tin, phù hợp với vị trí tuyển dụng;
- b) Có quy định, quy trình tuyển dụng cán bộ và điều kiện tuyển dụng cán bộ;
- c) Có chuyên gia trong lĩnh vực đánh giá, kiểm tra trình độ chuyên môn phù hợp với vị trí tuyển dụng.

9.1.3.2 Trong quá trình làm việc

- a) Có quy định về việc thực hiện nội quy, quy chế bảo đảm an toàn thông tin cho người sử dụng, cán bộ quản lý và vận hành hệ thống;
- b) Có kế hoạch và định kỳ hàng năm tổ chức phổ biến, tuyên truyền nâng cao nhận thức về an toàn thông tin cho người sử dụng;

c) Có kế hoạch và định kỳ hàng năm tổ chức đào tạo về an toàn thông tin cho 03 nhóm đối tượng bao gồm: cán bộ kỹ thuật, cán bộ quản lý và người sử dụng trong hệ thống;

d) Xây dựng tiêu chí đánh giá kỹ năng, kiến thức chuyên môn và nhận thức về an toàn thông tin đối với cán bộ ở các vị trí;

đ) Định kỳ hàng năm tiến hành kiểm tra kỹ năng, kiến thức chuyên môn, cũng như nhận thức về an toàn thông tin đối với cán bộ ở các vị trí.

9.1.3.3 Chấm dứt hoặc thay đổi công việc

a) Cán bộ chấm dứt hoặc thay đổi công việc phải thu hồi thẻ truy cập, thông tin được lưu trên các phương tiện lưu trữ, các trang thiết bị máy móc, phần cứng, phần mềm và các tài sản khác (nếu có) thuộc sở hữu của tổ chức;

b) Có quy trình và thực hiện vô hiệu hóa tất cả các quyền ra, vào, truy cập tài nguyên, quản trị hệ thống sau khi cán bộ thôi việc;

c) Có cam kết giữ bí mật thông tin liên quan đến tổ chức sau khi nghỉ việc.

9.1.4 Quản lý thiết kế, xây dựng hệ thống

9.1.4.1 Thiết kế an toàn hệ thống thông tin

a) Có tài liệu mô tả quy mô, phạm vi và đối tượng sử dụng, khai thác, quản lý vận hành hệ thống thông tin;

b) Có tài liệu mô tả thiết kế và các thành phần của hệ thống thông tin;

c) Có tài liệu mô tả phương án bảo đảm an toàn thông tin theo cấp độ;

d) Có tài liệu mô tả phương án lựa chọn giải pháp công nghệ bảo đảm an toàn thông tin;

đ) Khi có thay đổi thiết kế, đánh giá lại tính phù hợp của phương án thiết kế đối với các yêu cầu an toàn đặt ra đối với hệ thống;

e) Có phương án quản lý và bảo vệ hồ sơ thiết kế;

g) Có bộ phận chuyên môn, tổ chuyên gia đánh giá hồ sơ thiết kế hệ thống thông tin, các biện pháp bảo đảm an toàn thông tin trước khi triển khai thực hiện.

9.1.4.2 Phát triển phần mềm thuê khoán

a) Có biên bản, hợp đồng và các cam kết đối với bên thuê khoán các nội dung liên quan đến việc phát triển phần mềm thuê khoán;

b) Yêu cầu các nhà phát triển cung cấp mã nguồn phần mềm;

c) Kiểm thử phần mềm trên môi trường thử nghiệm và nghiệm thu trước khi đưa vào sử dụng;

- d) Kiểm tra, đánh giá an toàn thông tin, trước khi đưa vào sử dụng;
- d) Khi thay đổi mã nguồn, kiến trúc phần mềm thực hiện kiểm tra, đánh giá an toàn thông tin cho phần mềm;
- e) Có cam kết của bên phát triển về bảo đảm tính bí mật của mã nguồn và bản quyền của phần mềm phát triển.

9.1.4.3 Thử nghiệm và nghiệm thu hệ thống

- a) Thực hiện thử nghiệm và nghiệm thu hệ thống trước khi bàn giao và đưa vào sử dụng;
 - b) Có nội dung, kế hoạch, quy trình thử nghiệm và nghiệm thu hệ thống;
 - c) Có bộ phận có trách nhiệm thực hiện thử nghiệm và nghiệm thu hệ thống;
 - d) Có đơn vị độc lập (bên thứ ba) hoặc bộ phận độc lập thuộc đơn vị thực hiện tư vấn và giám sát quá trình thử nghiệm và nghiệm thu hệ thống;
 - d) Có báo cáo nghiệm thu được xác nhận của bộ phận chuyên trách và phê duyệt của chủ quản hệ thống thông tin trước khi đưa vào sử dụng.
-

9.1.5 Quản lý vận hành hệ thống

9.1.5.1 Quản lý an toàn mạng

Chính sách, quy trình quản lý an toàn mạng bao gồm:

- a) Quản lý, vận hành hoạt động bình thường của hệ thống;
- b) Cập nhật, sao lưu dự phòng và khôi phục hệ thống sau khi xảy ra sự cố;
- c) Truy cập và quản lý cấu hình hệ thống;
- d) Cấu hình tối ưu, tăng cường bảo mật cho thiết bị hệ thống (cứng hóa) trước khi đưa vào vận hành, khai thác.

9.1.5.2 Quản lý an toàn máy chủ và ứng dụng

Chính sách, quy trình quản lý an toàn máy chủ và ứng dụng bao gồm:

- a) Quản lý, vận hành hoạt động bình thường của hệ thống máy chủ và dịch vụ;
- b) Truy cập mạng của máy chủ;
- c) Truy cập và quản trị máy chủ và ứng dụng;
- d) Cập nhật, sao lưu dự phòng và khôi phục sau khi xảy ra sự cố;
- d) Cài đặt, gỡ bỏ hệ điều hành, dịch vụ, phần mềm trên hệ thống máy chủ và ứng dụng;

e) Kết nối và gỡ bỏ hệ thống máy chủ và dịch vụ khỏi hệ thống;

g) Cấu hình tối ưu và tăng cường bảo mật (cứng hóa) cho hệ thống máy chủ trước khi đưa vào vận hành, khai thác.

9.1.5.3 Quản lý an toàn dữ liệu

Chính sách, quy trình quản lý an toàn dữ liệu bao gồm:

a) Yêu cầu an toàn đối với phương pháp mã hóa;

b) Phân loại, quản lý và sử dụng khóa bí mật và dữ liệu mã hóa;

c) Cơ chế mã hóa và kiểm tra tính nguyên vẹn của dữ liệu;

d) Trao đổi dữ liệu qua môi trường mạng và phương tiện lưu trữ;

đ) Sao lưu dự phòng và khôi phục dữ liệu (tần suất sao lưu dự phòng, phương tiện lưu trữ, thời gian lưu trữ; nơi lưu trữ, phương thức lưu trữ và phương thức lấy dữ liệu ra khỏi phương tiện lưu trữ);

e) Cập nhật đồng bộ thông tin, dữ liệu giữa hệ thống sao lưu dự phòng chính và hệ thống phụ;

g) Định kỳ hoặc khi có thay đổi cấu hình trên hệ thống thực hiện quy trình sao lưu dự phòng: tập tin cấu hình hệ thống, bản dự phòng hệ điều hành máy chủ, cơ sở dữ liệu; dữ liệu, thông tin nghiệp vụ và các thông tin, dữ liệu quan trọng khác trên hệ thống (nếu có).

9.1.5.4 Quản lý an toàn thiết bị đầu cuối

Chính sách, quy trình quản lý thiết bị đầu cuối bao gồm:

a) Quản lý, vận hành hoạt động bình thường cho thiết bị đầu cuối;

b) Kết nối, truy cập và sử dụng thiết bị đầu cuối từ xa;

c) Cài đặt, kết nối và gỡ bỏ thiết bị đầu cuối trong hệ thống;

d) Cấu hình tối ưu và tăng cường bảo mật (cứng hóa) cho máy tính người sử dụng và thực hiện quy trình trước khi đưa hệ thống vào sử dụng;

đ) Kiểm tra, đánh giá, xử lý điểm yếu an toàn thông tin cho thiết bị đầu cuối trước khi đưa vào sử dụng.

9.1.5.5 Quản lý phòng chống phần mềm độc hại

Chính sách, quy trình quản lý phần mềm độc hại bao gồm:

a) Cài đặt, cập nhật, sử dụng phần mềm phòng chống mã độc; dò quét, kiểm tra phần mềm độc hại trên máy tính, máy chủ và thiết bị di động;

b) Cài đặt, sử dụng phần mềm trên máy tính, thiết bị di động và việc truy cập các trang thông tin trên mạng;

c) Gửi nhận tập tin qua môi trường mạng và các phương tiện lưu trữ di động;

d) Định kỳ thực hiện kiểm tra và dò quét phần mềm độc hại trên toàn bộ hệ thống; Thực hiện kiểm tra và xử lý phần mềm độc hại khi phát hiện dấu hiệu hoặc cảnh báo về dấu hiệu phần mềm độc hại xuất hiện trên hệ thống.

9.1.5.6 Quản lý giám sát an toàn hệ thống thông tin

Chính sách, quy trình quản lý giám sát an toàn hệ thống thông tin bao gồm:

a) Quản lý, vận hành hoạt động bình thường của hệ thống giám sát;

b) Đối tượng giám sát bao gồm: thiết bị hệ thống, máy chủ, ứng dụng, dịch vụ và các thành phần khác trong hệ thống (nếu có);

c) Kết nối và gửi nhật ký hệ thống từ đối tượng giám sát về hệ thống giám sát;

d) Truy cập và quản trị hệ thống giám sát;

đ) Loại thông tin cần được giám sát;

e) Lưu trữ và bảo vệ thông tin giám sát (nhật ký hệ thống);

g) Đồng bộ thời gian giữa hệ thống giám sát và thiết bị được giám sát;

h) Theo dõi, giám sát và cảnh báo sự cố phát hiện được trên hệ thống thông tin;

i) Bố trí nguồn lực và tổ chức giám sát an toàn hệ thống thông tin 24/7.

9.1.5.7 Quản lý điểm yếu an toàn thông tin

Chính sách, quy trình quản lý điểm yếu an toàn thông tin bao gồm:

a) Quản lý thông tin các thành phần có trong hệ thống có khả năng tồn tại điểm yếu an toàn thông tin: thiết bị hệ thống, hệ điều hành, máy chủ, ứng dụng, dịch vụ và các thành phần khác (nếu có);

b) Quản lý, cập nhật nguồn cung cấp điểm yếu an toàn thông tin; phân nhóm và mức độ của điểm yếu cho các thành phần trong hệ thống đã xác định;

c) Cơ chế phối hợp với các nhóm chuyên gia, bên cung cấp dịch vụ hỗ trợ trong việc xử lý, khắc phục điểm yếu an toàn thông tin;

d) Kiểm tra, đánh giá và xử lý điểm yếu an toàn thông tin cho thiết bị hệ thống, máy chủ, dịch vụ trước khi đưa vào sử dụng;

đ) Phương án xử lý tạm thời khi điểm yếu an toàn thông tin không/chưa có khả năng xử lý;

e) Quy trình khôi phục lại hệ thống sau khi xử lý điểm yếu an toàn thông tin thất bại;

g) Định kỳ kiểm tra, đánh giá điểm yếu an toàn thông tin cho toàn bộ hệ thống thông tin; Thực hiện quy trình kiểm tra, đánh giá, xử lý điểm yếu an toàn thông tin khi có thông tin hoặc nhận được cảnh báo về điểm yếu an toàn thông tin đối với thành phần cụ thể trong hệ thống.

9.1.5.8 Quản lý sự cố an toàn thông tin

Chính sách, quy trình quản lý sự cố an toàn thông tin bao gồm:

- a) Phân nhóm sự cố an toàn thông tin;
- b) Phương án tiếp nhận, phát hiện, phân loại và xử lý ban đầu sự cố an toàn thông tin;
- c) Kế hoạch ứng phó sự cố an toàn thông tin;
- d) Giám sát, phát hiện và cảnh báo sự cố an toàn thông tin;
- d) Quy trình ứng cứu sự cố an toàn thông tin thông thường;
- e) Quy trình ứng cứu sự cố an toàn thông tin nghiêm trọng;
- g) Cơ chế phối hợp với cơ quan chức năng, các nhóm chuyên gia, bên cung cấp dịch vụ hỗ trợ trong việc xử lý, khắc phục sự cố an toàn thông tin;
- h) Định kỳ tổ chức diễn tập phương án xử lý sự cố an toàn thông tin.

9.1.5.9 Quản lý an toàn người sử dụng đầu cuối

Chính sách, quy trình quản lý an toàn người sử dụng đầu cuối bao gồm:

- a) Quản lý truy cập, sử dụng tài nguyên nội bộ;
- b) Quản lý truy cập mạng và tài nguyên trên Internet;
- c) Cài đặt và sử dụng máy tính an toàn.

9.2 Yêu cầu kỹ thuật

9.2.1 Bảo đảm an toàn mạng

9.2.1.1 Thiết kế hệ thống

a) Thiết kế các vùng mạng trong hệ thống theo chức năng, các vùng mạng tối thiểu bao gồm:

- Vùng mạng nội bộ;
- Vùng mạng biên;
- Vùng DMZ;
- Vùng máy chủ nội bộ;
- Vùng mạng không dây (nếu có) tách riêng, độc lập với các vùng mạng khác;

- Vùng mạng máy chủ cơ sở dữ liệu;
- Vùng quản trị;
- Vùng quản trị thiết bị hệ thống.

b) Phương án thiết kế bảo đảm các yêu cầu sau:

- Có phương án quản lý truy cập, quản trị hệ thống từ xa an toàn;
- Có phương án quản lý truy cập giữa các vùng mạng và phòng chống xâm nhập;
- Có phương án cân bằng tải, dự phòng nóng cho các thiết bị mạng;
- Có phương án bảo đảm an toàn cho máy chủ cơ sở dữ liệu;
- Có phương án chặn lọc phần mềm độc hại trên môi trường mạng;
- Có phương án phòng chống tấn công từ chối dịch vụ;
- Có phương án giám sát hệ thống thông tin tập trung;
- Có phương án giám sát an toàn hệ thống thông tin tập trung;
- Có phương án quản lý sao lưu dự phòng tập trung;
- Có phương án quản lý phần mềm phòng chống mã độc trên các máy chủ/máy tính người dùng tập trung;
- Có phương án phòng, chống thất thoát dữ liệu;
- Có phương án duy trì ít nhất 02 kết nối mạng Internet từ các ISP sử dụng hạ tầng kết nối trong nước khác nhau (nếu hệ thống buộc phải có kết nối mạng Internet);
- Có phương án bảo đảm an toàn cho mạng không dây (nếu có);
- Có phương án quản lý tài khoản đặc quyền;
- Có phương án dự phòng hệ thống ở vị trí địa lý khác nhau;
- Có phương án dự phòng cho kết nối mạng giữa hệ thống chính và hệ thống dự phòng.

Trích dẫn yêu cầu:

- Thiết kế các vùng mạng theo chức năng (nội bộ, biên, DMZ, máy chủ nội bộ, không dây, CSDL, quản trị, quản trị thiết bị).
- Phương án thiết kế bảo đảm: quản lý truy cập/quản trị từ xa an toàn; quản lý truy cập giữa các vùng mạng và phòng chống xâm nhập; cân bằng tải, dự phòng nóng; bảo đảm an toàn máy chủ CSDL; chặn lọc phần mềm độc hại trên mạng; phòng chống tấn công từ chối dịch vụ; giám sát hệ thống & giám sát an toàn tập trung; sao lưu dự phòng tập trung; quản lý phần mềm phòng chống mã độc tập trung; phòng chống thất thoát dữ liệu; duy trì ≥ 2 kết nối Internet từ ISP khác nhau; bảo đảm an toàn mạng không dây; quản lý tài khoản đặc quyền; dự phòng hệ thống ở vị trí địa lý khác; dự phòng kết nối mạng giữa hệ thống chính và dự phòng.

Giải thích yêu cầu: Yêu cầu này đặt ra kiến trúc mạng phân vùng (network segmentation) nghiêm ngặt nhất cho hệ thống cấp độ 5 — hệ thống mà khi bị phá hoại sẽ ảnh hưởng đặc biệt nghiêm trọng đến quốc phòng, an ninh quốc gia. Mỗi vùng mạng phải được tách biệt rõ ràng theo chức năng để giới hạn phạm vi ảnh hưởng khi xảy ra sự cố (blast radius). Đồng thời yêu cầu tính sẵn sàng cao (HA), dự phòng thảm họa (DR), và khả năng giám sát/phát hiện toàn diện.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu cụ thể	Giải pháp
---	----------------	-----------

#	Yêu cầu cụ thể	Giải pháp
1	Phân vùng mạng theo chức năng (8 vùng)	Triển khai kiến trúc mạng phân tầng (Core-Distribution-Access) với VLAN/VRF tách biệt cho từng vùng. Sử dụng Next-Gen Firewall (Palo Alto, Fortinet, hoặc tương đương) đặt giữa các vùng để kiểm soát truy cập liên vùng.
2	Quản lý truy cập/quản trị từ xa an toàn	Triển khai VPN IPSec/SSL (site-to-site và remote access) kết hợp xác thực đa nhân tố (MFA). Sử dụng Jump Server / Bastion Host đặt trong vùng quản trị làm điểm trung chuyển duy nhất. Triển khai PAM (CyberArk, BeyondTrust) để quản lý phiên quản trị.
3	Quản lý truy cập giữa các vùng mạng & phòng chống xâm nhập	Thiết lập ACL/Security Policy trên firewall giữa các vùng theo nguyên tắc deny-all, allow-by-exception. Triển khai IPS (Intrusion Prevention System) inline tại các điểm giao giữa các vùng mạng.
4	Cân bằng tải, dự phòng nóng cho thiết bị mạng	Triển khai HA Active-Active hoặc Active-Standby cho firewall, switch core, router biên (VRRP/HSRP). Sử dụng Load Balancer (F5, HAProxy) cho dịch vụ.
5	Bảo đảm an toàn máy chủ CSDL	Đặt máy chủ CSDL trong vùng mạng riêng biệt, chỉ cho phép kết nối từ máy chủ ứng dụng qua cổng cụ thể. Triển khai Database Firewall (Imperva, Oracle Audit Vault). Mã hóa dữ liệu at-rest (TDE) và in-transit (TLS).
6	Chặn lọc phần mềm độc hại trên mạng	Triển khai hệ thống lọc phần mềm độc hại trên gateway (Sandbox: FireEye, Palo Alto WildFire, FortiSandbox). Kết hợp Web Application Firewall (WAF) cho ứng dụng web.
7	Phòng chống tấn công từ chối dịch vụ (DDoS)	Triển khai giải pháp Anti-DDoS tại tầng biên (Arbor Networks, Radware, Cloudflare on-premise). Kết hợp Rate Limiting, SYN Cookie trên firewall/load balancer.
8	Giám sát hệ thống thông tin tập trung	Triển khai hệ thống NMS (Network Monitoring System): Zabbix, PRTG, Nagios hoặc tương đương để giám sát hiệu năng, trạng thái thiết bị, dịch vụ.
9	Giám sát an toàn hệ thống thông tin tập trung	Triển khai SIEM (Splunk, IBM QRadar, ELK + Wazuh) để thu thập, phân tích log và cảnh báo sự kiện an ninh. Kết hợp SOC 24/7.
10	Sao lưu dự phòng tập trung	Triển khai hệ thống backup tập trung (Veeam, Commvault, Veritas) với NAS/SAN chuyên dụng. Thiết lập chính sách sao lưu 3-2-1 (3 bản sao, 2 loại phương tiện, 1 offsite).
11	Quản lý phần mềm phòng chống mã độc tập trung	Triển khai EDR/EPP có quản lý tập trung (CrowdStrike, Kaspersky Security Center, Symantec Endpoint Protection Manager).

#	Yêu cầu cụ thể	Giải pháp
12	Phòng chống thất thoát dữ liệu (DLP)	Triển khai giải pháp DLP (Symantec DLP, Forcepoint, Digital Guardian) giám sát endpoint, network, email gateway.
13	Duy trì ≥ 2 kết nối Internet từ ISP khác nhau	Ký hợp đồng với tối thiểu 2 ISP sử dụng hạ tầng kết nối trong nước khác nhau (VD: VNPT + Viettel). Cấu hình BGP hoặc policy-based routing để failover tự động.
14	Bảo đảm an toàn mạng không dây	Sử dụng WPA3-Enterprise, xác thực qua RADIUS/802.1X. Tách biệt VLAN mạng không dây với mạng nội bộ. Triển khai WIPS (Wireless Intrusion Prevention System).
15	Quản lý tài khoản đặc quyền (PIM)	Triển khai giải pháp PAM/PIM (CyberArk, BeyondTrust, Thales) để kiểm soát, ghi nhận và xoay vòng tài khoản đặc quyền tự động.
16	Dự phòng hệ thống ở vị trí địa lý khác (DR)	Thiết lập Data Center dự phòng (DR Site) ở vị trí địa lý cách xa $\geq 30\text{km}$. Đồng bộ dữ liệu theo chế độ near real-time. Định kỳ diễn tập DR switchover.
17	Dự phòng kết nối mạng giữa hệ thống chính và dự phòng	Thuê ≥ 2 đường truyền leased-line/MPLS từ các nhà cung cấp khác nhau giữa DC chính và DR. Cấu hình failover tự động.

9.2.1.2 Kiểm soát truy cập từ bên ngoài mạng

a) Thiết lập hệ thống chỉ cho phép sử dụng các kết nối mạng an toàn khi truy cập thông tin nội bộ hoặc quản trị hệ thống từ các mạng bên ngoài và mạng Internet;

b) Kiểm soát truy cập từ bên ngoài vào hệ thống theo từng dịch vụ, ứng dụng cụ thể; chặn tất cả truy cập tới các dịch vụ, ứng dụng mà hệ thống không cung cấp hoặc không cho phép truy cập từ bên ngoài;

c) Thiết lập giới hạn thời gian chờ (timeout) để đóng phiên kết nối khi hệ thống không nhận được yêu cầu từ người dùng;

d) Phân quyền và cấp quyền truy cập từ bên ngoài vào hệ thống theo từng người dùng hoặc nhóm người dùng căn cứ theo yêu cầu nghiệp vụ, yêu cầu quản lý;

đ) Giới hạn số lượng kết nối đồng thời từ một địa chỉ nguồn và tổng số lượng kết nối đồng thời cho từng ứng dụng, dịch vụ được hệ thống cung cấp theo năng lực thực tế của hệ thống;

e) Có phương án ưu tiên, bảo đảm chất lượng dịch vụ (QoS) cho các ứng dụng, dịch vụ quan trọng.

Trích dẫn yêu cầu:

- Chỉ cho phép kết nối mạng an toàn khi truy cập nội bộ/quản trị từ bên ngoài và Internet.
- Kiểm soát truy cập theo từng dịch vụ, ứng dụng; chặn mọi truy cập không được phép.

- Thiết lập timeout để đóng phiên kết nối khi không hoạt động.
- Phân quyền truy cập từ bên ngoài theo người dùng/nhóm người dùng.
- Giới hạn số lượng kết nối đồng thời từ một địa chỉ nguồn và tổng kết nối cho từng dịch vụ.
- Có phương án QoS cho ứng dụng, dịch vụ quan trọng.

Giải thích yêu cầu: Yêu cầu này nhằm kiểm soát chặt chẽ mọi luồng truy cập từ bên ngoài vào hệ thống. Mục tiêu là giảm thiểu bề mặt tấn công (attack surface) bằng cách chỉ mở đúng những dịch vụ cần thiết, giới hạn phiên kết nối để tránh session hijacking, giới hạn kết nối đồng thời để phòng chống DDoS/brute-force, và ưu tiên băng thông cho dịch vụ quan trọng.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Kết nối mạng an toàn từ bên ngoài	Bắt buộc sử dụng VPN (IPSec/SSL) + MFA khi truy cập từ bên ngoài. Tất cả giao thức quản trị phải dùng SSH, HTTPS, không dùng Telnet, HTTP.
2	Kiểm soát theo dịch vụ, chặn mặc định	Cấu hình firewall theo nguyên tắc "Default Deny" — chỉ mở port/protocol được phê duyệt. Sử dụng Application-aware firewall để kiểm soát ở tầng ứng dụng (L7).
3	Timeout phiên kết nối	Cấu hình session timeout trên firewall (idle timeout ≤ 15 phút), VPN gateway, và ứng dụng.
4	Phân quyền truy cập theo người dùng/nhóm	Tích hợp xác thực với LDAP/AD, sử dụng RBAC. Cấu hình firewall policy per-user/per-group kết hợp Identity-based policy.
5	Giới hạn kết nối đồng thời	Cấu hình connection limit per source IP và per service trên firewall/load balancer. Thiết lập rate limiting trên reverse proxy/WAF.
6	QoS cho dịch vụ quan trọng	Cấu hình QoS policy (DSCP marking, traffic shaping, priority queuing) trên router/switch biên. Ưu tiên băng thông cho dịch vụ nghiệp vụ cốt lõi.

9.2.1.3 Kiểm soát truy cập từ bên trong mạng

- Chỉ cho phép truy cập các ứng dụng, dịch vụ bên ngoài theo yêu cầu nghiệp vụ, chặn các dịch vụ khác không phục vụ hoạt động nghiệp vụ theo chính sách của tổ chức;
- Có phương án kiểm soát truy cập của người dùng vào các dịch vụ, các máy chủ nội bộ theo chức năng và chính sách của tổ chức;
- Không cho phép hoặc giới hạn truy cập (theo chức năng của máy chủ) từ các máy chủ ra các mạng bên ngoài hệ thống;
- Có phương án quản lý các thiết bị đầu cuối, máy tính người dùng kết nối vào hệ thống mạng (theo địa chỉ vật lý, địa chỉ logic), chỉ cho phép thiết bị đầu cuối, máy tính người sử dụng hợp lệ kết nối vào hệ thống;
- Triển khai hệ thống giám sát, phát hiện và ngăn chặn truy cập từ bên trong mạng đến các địa chỉ Internet bị cấm truy cập theo chính sách của tổ chức (nếu có);

e) Có phương án ưu tiên, bảo đảm chất lượng dịch vụ (QoS) cho các kết nối mạng quan trọng.

Trích dẫn yêu cầu:

- Chỉ cho phép truy cập dịch vụ bên ngoài theo yêu cầu nghiệp vụ, chặn dịch vụ khác.
- Kiểm soát truy cập người dùng vào máy chủ nội bộ theo chức năng.
- Không cho phép/giới hạn truy cập từ máy chủ ra mạng bên ngoài.
- Quản lý thiết bị đầu cuối kết nối vào mạng (theo MAC, IP), chỉ cho phép thiết bị hợp lệ.
- Giám sát, phát hiện và ngăn chặn truy cập đến địa chỉ Internet bị cấm.
- Có phương án QoS cho các kết nối mạng quan trọng.

Giải thích yêu cầu: Yêu cầu này tập trung kiểm soát luồng lưu lượng từ bên trong mạng đi ra ngoài và giữa các vùng nội bộ. Mục đích chống insider threat, ngăn chặn malware gọi về C&C server, phát hiện lateral movement, và đảm bảo chỉ thiết bị được cấp phép mới truy cập được hệ thống.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Chỉ cho phép truy cập dịch vụ bên ngoài theo nghiệp vụ	Cấu hình outbound firewall policy theo whitelist. Sử dụng Web Proxy/Secure Web Gateway (Squid, Zscaler) để kiểm soát truy cập Internet.
2	Kiểm soát truy cập vào máy chủ nội bộ	Áp dụng micro-segmentation giữa các vùng. Cấu hình ACL trên firewall nội bộ theo nguyên tắc least privilege, chỉ mở port/service cần thiết cho từng nhóm người dùng.
3	Hạn chế máy chủ truy cập ra ngoài	Cấu hình outbound firewall rule cho server zone: chỉ cho phép cập nhật patch, NTP, DNS. Block mọi kết nối ra Internet khác.
4	Quản lý thiết bị đầu cuối (NAC)	Triển khai Network Access Control (Cisco ISE, Aruba ClearPass, FortiNAC). Xác thực thiết bị theo 802.1X, kiểm tra MAC + IP binding.
5	Ngăn chặn truy cập địa chỉ Internet bị cấm	Triển khai DNS filtering (Pi-hole, Cisco Umbrella) và URL filtering trên proxy/firewall. Tích hợp Threat Intelligence Feed để tự động cập nhật danh sách cấm.
6	QoS cho kết nối quan trọng	Cấu hình QoS trên switch/router nội bộ: priority queuing cho traffic nghiệp vụ, bandwidth reservation cho hệ thống giám sát và backup.

9.2.1.4 Nhật ký hệ thống

a) Thiết lập chức năng ghi, lưu trữ nhật ký hệ thống trên các thiết bị hệ thống (nếu hỗ trợ), bao gồm các thông tin sau:

- Thời gian kết nối;
- Thông tin kết nối mạng (địa chỉ IP, cổng kết nối);
- Hành động đối với kết nối (cho phép, ngăn chặn);
- Thông tin các thiết bị đầu cuối kết nối vào hệ thống theo địa chỉ vật lý và logic;

- Thông tin cảnh báo từ các thiết bị;
- Thông tin hiệu năng hoạt động của thiết bị và tài nguyên mạng.

b) Sử dụng máy chủ thời gian trong hệ thống để đồng bộ thời gian giữa các thiết bị mạng, thiết bị đầu cuối và các thành phần khác trong hệ thống tham gia hoạt động giám sát;

c) Lưu trữ và quản lý tập trung nhật ký hệ thống thu thập được từ các thiết bị hệ thống;

d) Giới hạn tài nguyên cho chức năng ghi nhật ký trên thiết bị, để bảo đảm chức năng này không làm ảnh hưởng, gián đoạn hoạt động của thiết bị;

đ) Lưu trữ dự phòng dữ liệu nhật ký hệ thống trên hệ thống lưu trữ riêng biệt, có mã hóa với những dữ liệu nhật ký quan trọng (nếu có);

e) Lưu trữ nhật ký hệ thống của thiết bị tối thiểu 12 tháng;

g) Phân quyền truy cập, quản lý dữ liệu nhật ký hệ thống đối với các tài khoản có chức năng quản trị hệ thống khác nhau.

Trích dẫn yêu cầu:

- Ghi nhật ký hệ thống trên thiết bị: thời gian kết nối, thông tin kết nối mạng (IP, port), hành động, thông tin thiết bị đầu cuối, cảnh báo, hiệu năng.
- Đồng bộ thời gian bằng máy chủ thời gian (NTP).
- Lưu trữ và quản lý tập trung nhật ký.
- Giới hạn tài nguyên ghi nhật ký để không ảnh hưởng thiết bị.
- Lưu trữ dự phòng nhật ký trên hệ thống riêng biệt, mã hóa nhật ký quan trọng.
- Lưu trữ tối thiểu 12 tháng.
- Phân quyền truy cập quản lý nhật ký.

Giải thích yêu cầu: Yêu cầu thiết lập hệ thống logging toàn diện cho hạ tầng mạng. Nhật ký hệ thống là bằng chứng số (digital evidence) thiết yếu cho điều tra sự cố, phát hiện xâm nhập và kiểm toán (audit). Việc đồng bộ thời gian đảm bảo correlation chính xác giữa các sự kiện. Yêu cầu 12 tháng lưu trữ phục vụ forensics và tuân thủ pháp luật.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Ghi nhật ký trên thiết bị	Bật Syslog trên tất cả thiết bị mạng (firewall, switch, router, IPS). Cấu hình log level phù hợp (Informational trở lên). Bật NetFlow/sFlow cho phân tích traffic.
2	Đồng bộ thời gian (NTP)	Triển khai NTP server nội bộ (stratum 2-3) đồng bộ từ nguồn tin cậy. Cấu hình tất cả thiết bị, máy chủ trỏ về NTP server nội bộ. Sử dụng NTP authentication.
3	Lưu trữ & quản lý tập trung	Triển khai SIEM (Splunk, QRadar, ELK+Wazuh) hoặc Log Collector tập trung. Tất cả thiết bị forward syslog về hệ thống tập trung qua kênh mã hóa (TLS).

#	Yêu cầu	Giải pháp
4	Giới hạn tài nguyên ghi log	Cấu hình log rotation, log buffer size trên thiết bị. Đặt disk quota cho log partition. Sử dụng remote logging để giảm tải cho thiết bị.
5	Lưu trữ dự phòng & mã hóa	Sao lưu log sang hệ thống lưu trữ riêng (NAS/SAN offline). Mã hóa log nhạy cảm bằng AES-256. Áp dụng WORM (Write Once Read Many) storage cho log quan trọng.
6	Lưu trữ ≥12 tháng	Thiết lập retention policy: hot storage (1-3 tháng SSD/HDD) → warm storage (3-6 tháng) → cold storage (6-12+ tháng tape/archive).
7	Phân quyền truy cập log	Áp dụng RBAC trên SIEM: admin có full access, analyst chỉ đọc, auditor chỉ xem báo cáo. Ghi audit log cho mọi truy cập vào dữ liệu nhật ký.

9.2.1.5 Phòng chống xâm nhập

- a) Có phương án phòng chống xâm nhập để bảo vệ các vùng mạng trong hệ thống;
- b) Định kỳ cập nhật cơ sở dữ liệu dấu hiệu phát hiện tấn công mạng (Signatures);
- c) Bảo đảm năng lực hệ thống đáp ứng đủ theo yêu cầu, quy mô số lượng người dùng và dịch vụ, dụng của hệ thống cung cấp;
- d) Hệ thống có phương án cân bằng tải và dự phòng nóng.

9.2.1.6 Phòng chống phần mềm độc hại trên môi trường mạng

- a) Có phương án phòng chống phần mềm độc hại trên môi trường mạng;
- b) Định kỳ cập nhật dữ liệu cho hệ thống phòng chống phần mềm độc hại;
- c) Bảo đảm năng lực hệ thống đáp ứng đủ theo yêu cầu, quy mô số lượng người dùng và dịch vụ, ứng dụng của hệ thống cung cấp;
- d) Hệ thống có phương án cân bằng tải và dự phòng nóng.

Trích dẫn yêu cầu:

- Có phương án phòng chống xâm nhập bảo vệ các vùng mạng; cập nhật Signatures định kỳ; năng lực đáp ứng quy mô; cân bằng tải và dự phòng nóng.
- Có phương án phòng chống phần mềm độc hại trên mạng; cập nhật dữ liệu định kỳ; năng lực đáp ứng; cân bằng tải và dự phòng nóng.

Giải thích yêu cầu: Hai mục 9.2.1.5 và 9.2.1.6 yêu cầu triển khai lớp bảo vệ phát hiện và ngăn chặn tấn công mạng (IDS/IPS) cùng lớp lọc phần mềm độc hại ngay trên môi trường mạng (network-level). Đây là defense-in-depth tại tầng network, bổ sung cho bảo vệ tại endpoint. Hệ thống phải có năng lực xử lý đủ throughput và tính sẵn sàng cao.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Phòng chống xâm nhập (IPS)	Triển khai IPS inline (Palo Alto, FortiGate IPS, Snort/Suricata) tại các điểm giao giữa các vùng mạng. Đặt sensor tại biên Internet, giữa LAN-DMZ, LAN-Server zone.
2	Cập nhật Signatures	Thiết lập auto-update signatures hàng ngày. Sử dụng Threat Intelligence Feed bổ sung. Kiểm tra tính tương thích trước khi áp dụng signature mới lên production.
3	Phòng chống phần mềm độc hại trên mạng	Triển khai Network Sandbox (FireEye NX, Palo Alto WildFire, FortiSandbox) phân tích file/URL nghi ngờ. Kết hợp Mail Security Gateway (Proofpoint, Mimecast) cho email.
4	Cập nhật dữ liệu malware	Thiết lập auto-update malware database. Đăng ký Threat Intelligence từ nhiều nguồn (VirusTotal, MISP, CERT quốc gia).
5	Năng lực & cân bằng tải, dự phòng nóng	Sizing IPS/Sandbox theo peak throughput + 30% headroom. Triển khai HA Active-Active hoặc Active-Standby. Sử dụng load balancer phân tải traffic qua nhiều sensor.

9.2.1.7 Bảo vệ thiết bị hệ thống

a) Cấu hình chức năng xác thực trên các thiết bị hệ thống để xác thực người dùng khi quản trị thiết bị trực tiếp hoặc từ xa;

b) Thiết lập cấu hình chỉ cho phép sử dụng các kết nối mạng an toàn khi truy cập, quản trị thiết bị từ xa;

c) Không cho phép quản trị, cấu hình thiết bị trực tiếp từ các mạng bên ngoài, trường hợp bắt buộc phải quản trị thiết bị từ xa phải thực hiện gián tiếp thông qua các máy quản trị trong hệ thống và sử dụng kết nối mạng an toàn;

d) Hạn chế được số lần đăng nhập sai khi quản trị hoặc kết nối quản trị từ xa theo địa chỉ mạng;

đ) Phân quyền truy cập, quản trị thiết bị đối với các tài khoản quản trị có quyền hạn khác nhau;

e) Nâng cấp, xử lý điểm yếu an toàn thông tin của thiết bị hệ thống trước khi đưa vào sử dụng;

g) Cấu hình tối ưu, tăng cường bảo mật cho hệ thống thiết bị hệ thống trước khi đưa vào sử dụng;

h) Xóa bỏ thông tin cấu hình, dữ liệu trên thiết bị hệ thống khi thay đổi mục đích sử dụng hoặc gỡ bỏ khỏi hệ thống.

Trích dẫn yêu cầu:

- Xác thực người dùng khi quản trị trực tiếp/từ xa.
- Chỉ dùng kết nối mạng an toàn khi quản trị từ xa.
- Không quản trị trực tiếp từ mạng bên ngoài; nếu bắt buộc phải gián tiếp qua máy quản trị nội bộ.
- Hạn chế số lần đăng nhập sai.

- Phân quyền truy cập, quản trị thiết bị.
- Nâng cấp, xử lý điểm yếu trước khi đưa vào sử dụng.
- Cấu hình tối ưu, tăng cường bảo mật (hardening).
- Xóa bỏ cấu hình/dữ liệu khi gỡ bỏ hoặc thay đổi mục đích.

Giải thích yêu cầu: Yêu cầu bảo vệ bản thân các thiết bị hạ tầng mạng (switch, router, firewall, IPS...) khỏi bị chiếm quyền điều khiển. Nếu kẻ tấn công chiếm được thiết bị mạng, toàn bộ hệ thống sẽ bị compromise. Do đó cần kiểm soát chặt chẽ việc quản trị thiết bị và hardening trước khi đưa vào vận hành.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Xác thực quản trị	Sử dụng RADIUS/TACACS+ server tập trung để xác thực quản trị viên. Bật local fallback account với mật khẩu mạnh.
2	Kết nối an toàn	Chỉ dùng SSH (v2), HTTPS cho quản trị. Vô hiệu hóa Telnet, HTTP, SNMP v1/v2 (chỉ dùng SNMPv3).
3	Cấm quản trị trực tiếp từ bên ngoài	Chỉ cho phép quản trị từ vùng quản trị (Management Zone). Truy cập từ xa phải qua VPN → Jump Server → thiết bị.
4	Hạn chế đăng nhập sai	Cấu hình login block-for (VD: block 5 phút sau 3 lần sai). Kết hợp fail2ban hoặc tương đương.
5	Phân quyền quản trị	Sử dụng privilege levels (Cisco), RBAC (Juniper/Palo Alto). Tách tài khoản read-only, operator, admin.
6	Xử lý điểm yếu trước vận hành	Kiểm tra firmware/CVE trước triển khai. Áp dụng bản vá mới nhất. Thực hiện vulnerability scan trước khi đưa vào production.
7	Hardening thiết bị	Áp dụng CIS Benchmark hoặc vendor hardening guide. Tắt dịch vụ không dùng, cổng không dùng. Bật control plane policing.
8	Xóa dữ liệu khi gỡ bỏ	Factory reset thiết bị. Xóa startup/running config, crypto keys. Kiểm tra bằng cách khởi động lại để xác nhận sạch dữ liệu.

9.2.2 Bảo đảm an toàn máy chủ

9.2.2.1 Xác thực

a) Thiết lập chính sách xác thực trên máy chủ để xác thực người dùng khi truy cập, quản lý và sử dụng máy chủ;

b) Thay đổi các tài khoản mặc định trên hệ thống hoặc vô hiệu hóa (nếu không sử dụng);

c) Thiết lập cấu hình máy chủ để đảm bảo an toàn mật khẩu người sử dụng, bao gồm các yêu cầu sau:

- Yêu cầu thay đổi mật khẩu mặc định;
- Thiết lập quy tắc đặt mật khẩu về số ký tự, loại ký tự;
- Thiết lập thời gian yêu cầu thay đổi mật khẩu;
- Thiết lập thời gian mật khẩu hợp lệ.

- d) Hạn chế số lần đăng nhập sai trong khoảng thời gian nhất định với một tài khoản nhất định;
- d) Thiết lập cấu hình để vô hiệu hóa tài khoản nếu tài khoản đó đăng nhập sai nhiều lần vượt số lần quy định;
- e) Thiết lập hệ thống để chỉ cho phép đăng nhập vào hệ thống vào khoảng thời gian hợp lệ (theo quy định của tổ chức);
- g) Sử dụng cơ chế xác thực đa nhân tố để xác thực người sử dụng khi truy cập, quản trị vào các máy chủ trong hệ thống.

Trích dẫn yêu cầu:

- Xác thực người dùng khi truy cập, quản lý, sử dụng máy chủ.
- Thay đổi/vô hiệu hóa tài khoản mặc định.
- Chính sách mật khẩu: thay đổi mật khẩu mặc định, quy tắc đặt mật khẩu, thời gian thay đổi, thời gian hợp lệ.
- Hạn chế số lần đăng nhập sai.
- Vô hiệu hóa tài khoản đăng nhập sai nhiều lần.
- Chỉ cho phép đăng nhập trong khoảng thời gian hợp lệ.
- Sử dụng xác thực đa nhân tố (MFA).

Giải thích yêu cầu: Yêu cầu thiết lập cơ chế xác thực mạnh mẽ nhất cho máy chủ — lớp bảo vệ đầu tiên ngăn truy cập trái phép. Ở cấp độ 5, bắt buộc MFA cho mọi truy cập quản trị máy chủ, kết hợp chính sách mật khẩu nghiêm ngặt và cơ chế khóa tài khoản tự động.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Xác thực người dùng	Tích hợp xác thực tập trung qua LDAP/Active Directory. Mọi tài khoản truy cập máy chủ phải được xác thực.
2	Tài khoản mặc định	Đổi tên tài khoản root/administrator. Vô hiệu hóa tài khoản guest, default. Tạo tài khoản quản trị riêng cho từng người.
3	Chính sách mật khẩu	Cấu hình PAM (Linux) hoặc Group Policy (Windows): độ dài ≥12 ký tự, bao gồm chữ hoa/thường/số/ký tự đặc biệt. Thay đổi mật khẩu mỗi 90 ngày. Không tái sử dụng 12 mật khẩu gần nhất.
4	Hạn chế đăng nhập sai	Cấu hình pam_tally2/faillock (Linux) hoặc Account Lockout Policy (Windows): khóa tài khoản sau 5 lần sai trong 15 phút.
5	Vô hiệu hóa tài khoản	Tự động disable tài khoản bị brute-force. Thông báo cho admin qua email/SIEM alert. Yêu cầu admin unlock thủ công.
6	Đăng nhập theo thời gian hợp lệ	Cấu hình logon hours trên AD/LDAP. Sử dụng PAM time module (Linux). Từ chối SSH/RDP ngoài giờ làm việc.

#	Yêu cầu	Giải pháp
7	Xác thực đa nhân tố (MFA)	Triển khai MFA cho SSH (Google Authenticator, Duo Security), RDP (Azure MFA, RSA SecurID). Sử dụng hardware token hoặc TOTP app.

9.2.2.2 Kiểm soát truy cập

- a) Thiết lập hệ thống chỉ cho phép sử dụng các kết nối mạng an toàn khi truy cập, quản trị máy chủ từ xa;
- b) Thiết lập giới hạn thời gian chờ (timeout) để đóng phiên kết nối khi máy chủ không nhận được yêu cầu từ người dùng;
- c) Thay đổi cổng quản trị mặc định của máy chủ;
- d) Không cho phép quản trị, cấu hình máy chủ trực tiếp từ các mạng bên ngoài, trường hợp bắt buộc phải quản trị thiết bị từ xa phải thực hiện gián tiếp thông qua các máy quản trị trong hệ thống và sử dụng kết nối mạng an toàn;
- đ) Phân quyền truy cập, quản trị, sử dụng tài nguyên khác nhau trên máy chủ với người sử dụng/ nhóm người sử dụng có chức năng, yêu cầu nghiệp vụ khác nhau;
- e) Cấp quyền tối thiểu (quyền truy cập, quản trị) cho tài khoản quản trị máy chủ theo quyền hạn;
- g) Kiểm soát truy cập máy chủ theo khoảng thời gian hợp lệ (theo chính sách của tổ chức nếu có).

Trích dẫn yêu cầu:

- Chỉ dùng kết nối an toàn khi quản trị máy chủ từ xa.
- Thiết lập timeout đóng phiên kết nối.
- Thay đổi cổng quản trị mặc định.
- Không quản trị trực tiếp từ mạng bên ngoài; gián tiếp qua máy quản trị nội bộ.
- Phân quyền truy cập, quản trị theo người dùng/nhóm.
- Cấp quyền tối thiểu (least privilege).
- Kiểm soát truy cập theo thời gian hợp lệ.

Giải thích yêu cầu: Yêu cầu kiểm soát chặt chẽ ai được truy cập máy chủ, bằng cách nào, và khi nào. Nguyên tắc cốt lõi là least privilege — mỗi tài khoản chỉ có quyền tối thiểu cần thiết. Cổng quản trị mặc định bị thay đổi để tránh scanning tự động.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Kết nối an toàn	Chỉ dùng SSH (thay Telnet), HTTPS (thay HTTP), RDP qua TLS. Vô hiệu hóa giao thức không mã hóa.
2	Timeout phiên	Cấu hình SSH ClientAliveInterval (300s), TMOUT trên bash. Cấu hình RDP session timeout (15 phút).

#	Yêu cầu	Giải pháp
3	Thay đổi cổng mặc định	Đổi SSH port (VD: 2222 thay 22), RDP port (VD: 3390 thay 3389). Cấu hình tương ứng trên firewall.
4	Cấm quản trị trực tiếp từ bên ngoài	Chỉ cho phép quản trị qua Jump Server/Bastion Host trong vùng quản trị. Truy cập từ xa phải qua VPN → Jump Server → máy chủ đích.
5	Phân quyền RBAC	Sử dụng sudo (Linux), AD Group Policy (Windows) phân quyền chi tiết. Tách biệt DB admin, OS admin, App admin.
6	Quyền tối thiểu	Không cấp root/admin trực tiếp. Sử dụng sudo với command whitelist. Ghi log mọi lệnh sudo.
7	Kiểm soát theo thời gian	Cấu hình cron/scheduled task tự động disable tài khoản quản trị ngoài giờ hành chính. Cho phép override qua quy trình phê duyệt khẩn cấp.

9.2.2.3 Nhật ký hệ thống

a) Ghi nhật ký hệ thống bao gồm những thông tin cơ bản sau:

- Thông tin kết nối mạng tới máy chủ (Firewall log);
- Thông tin đăng nhập vào máy chủ;
- Lỗi phát sinh trong quá trình hoạt động;
- Thông tin thay đổi cấu hình máy chủ;
- Thông tin truy cập dữ liệu và dịch vụ quan trọng trên máy chủ (nếu có).

b) Giới hạn dung lượng lưu trữ nhật ký hệ thống để không mất hoặc tràn nhật ký hệ thống;

c) Quản lý và lưu trữ tập trung nhật ký hệ thống thu thập được từ máy chủ;

d) Lưu nhật ký hệ thống trong khoảng thời gian tối thiểu là 12 tháng;

- đ) Lưu trữ dự phòng dữ liệu nhật ký hệ thống trên hệ thống lưu trữ riêng biệt, có mã hóa với những dữ liệu nhật ký quan trọng (nếu có);
- e) Phân quyền truy cập, quản lý dữ liệu nhật ký hệ thống đối với các tài khoản có chức năng quản trị hệ thống khác nhau.

Trích dẫn yêu cầu:

- Ghi nhật ký: kết nối mạng (Firewall log), đăng nhập, lỗi, thay đổi cấu hình, truy cập dữ liệu/dịch vụ quan trọng.
- Giới hạn dung lượng lưu trữ log để không tràn.
- Quản lý và lưu trữ tập trung.
- Lưu tối thiểu 12 tháng.
- Dự phòng nhật ký trên hệ thống riêng, mã hóa nhật ký quan trọng.
- Phân quyền truy cập quản lý nhật ký.

Giải thích yêu cầu: Yêu cầu ghi và bảo quản nhật ký chi tiết trên máy chủ phục vụ mục đích forensics, kiểm toán và phát hiện xâm nhập. Nhật ký máy chủ ghi lại mọi hoạt động: ai đăng nhập, làm gì, khi nào. Dữ liệu nhật ký phải được bảo vệ khỏi sửa đổi, xóa trái phép.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Ghi nhật ký chi tiết	Cấu hình rsyslog/journald (Linux), Windows Event Log. Bật audit log: auditd (Linux), Advanced Audit Policy (Windows). Ghi log đăng nhập, sudo, cấu hình, truy cập file nhạy cảm.
2	Giới hạn dung lượng	Cấu hình logrotate (Linux), max log size (Windows). Tách partition riêng cho /var/log. Cảnh báo khi disk usage ≥80%.
3	Lưu trữ tập trung	Forward log qua Syslog/TLS, Windows Event Forwarding về SIEM tập trung. Sử dụng Filebeat/Fluentd làm log shipper.
4	Lưu ≥12 tháng	Retention policy trên SIEM: hot (3 tháng), warm (6 tháng), cold archive (12+ tháng).
5	Dự phòng & mã hóa	Replicate log sang storage riêng (NAS/tape). Mã hóa AES-256 cho log chứa thông tin nhạy cảm. WORM storage để chống sửa đổi.
6	Phân quyền	RBAC trên SIEM và trên OS (chỉ root/admin được xem log hệ thống). Ghi audit trail khi truy cập log.

9.2.2.4 Phòng chống xâm nhập

- a) Loại bỏ các tài khoản không sử dụng, các tài khoản không còn hợp lệ trên máy chủ;
- b) Sử dụng tường lửa của hệ điều hành và hệ thống để cấm các truy cập trái phép tới máy chủ;
- c) Vô hiệu hóa các giao thức mạng không an toàn, các dịch vụ hệ thống không sử dụng;
- d) Có phương án cập nhật bản vá, xử lý điểm yếu an toàn thông tin cho hệ điều hành và các dịch vụ hệ thống trên máy chủ;
- đ) Thực hiện nâng cấp, xử lý điểm yếu an toàn thông tin trên máy chủ trước khi đưa vào sử dụng;
- e) Có biện pháp quản lý tập trung việc cập nhật và xử lý bản vá, điểm yếu an toàn thông tin cho hệ điều hành và các dịch vụ hệ thống trên máy chủ;
- g) Thực hiện cấu hình tối ưu, tăng cường bảo mật cho máy chủ trước khi đưa vào sử dụng;
- h) Có biện pháp phòng chống xâm nhập trên máy chủ và kiểm tra tính nguyên vẹn của các tập tin hệ thống.

Trích dẫn yêu cầu:

- Loại bỏ tài khoản không sử dụng/không hợp lệ.
- Sử dụng tường lửa OS và hệ thống.
- Vô hiệu hóa giao thức không an toàn, dịch vụ không dùng.
- Cập nhật bản vá, xử lý điểm yếu.
- Xử lý điểm yếu trước khi đưa vào sử dụng.
- Quản lý tập trung việc cập nhật bản vá.
- Hardening máy chủ.
- Phòng chống xâm nhập trên máy chủ và kiểm tra tính nguyên vẹn file.

Giải thích yêu cầu: Yêu cầu giảm bề mặt tấn công trên máy chủ bằng cách loại bỏ mọi thành phần không cần thiết (tài khoản, dịch vụ, giao thức) và chủ động vá lỗ hổng. Đồng thời triển khai HIDS/HIPS để phát hiện xâm nhập và kiểm tra tính nguyên vẹn để phát hiện file bị thay đổi trái phép.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Loại bỏ tài khoản không dùng	Rà soát định kỳ (hàng tháng) danh sách tài khoản. Tự động hóa bằng script kiểm tra tài khoản inactive >30 ngày. Tích hợp với HR offboarding workflow.
2	Tường lửa OS	Bật iptables/nftables (Linux), Windows Firewall. Default deny inbound, chỉ mở port cần thiết.
3	Vô hiệu hóa giao thức/dịch vụ không dùng	Tắt FTP, Telnet, rsh, rlogin. Disable dịch vụ không cần (cups, avahi, bluetooth...). Sử dụng systemctl disable.
4	Cập nhật bản vá tập trung	Triển khai WSUS (Windows), Satellite/Spacewalk (Linux). Lập lịch patch hàng tháng. Test patch trên staging trước.
5	Xử lý điểm yếu trước vận hành	Scan vulnerability (Nessus, OpenVAS) trước khi đưa máy chủ vào production. Không triển khai nếu còn lỗ hổng Critical/High.
6	Hardening máy chủ	Áp dụng CIS Benchmark cho từng OS (CentOS, Ubuntu, Windows Server). Sử dụng Ansible/Puppet để hardening tự động và nhất quán.
7	HIDS & kiểm tra nguyên vẹn	Triển khai OSSEC/Wazuh (HIDS). Sử dụng AIDE/Tripwire kiểm tra tính nguyên vẹn file hệ thống. Cảnh báo real-time về SIEM khi phát hiện thay đổi.

9.2.2.5 Phòng chống phần mềm độc hại

a) Cài đặt phần mềm phòng chống mã độc (hoặc có phương án khác tương đương) và thiết lập chế độ tự động cập nhật cơ sở dữ liệu cho phần mềm;

b) Có phương án kiểm tra, dò quét, xử lý phần mềm độc hại cho các phần mềm trước khi cài đặt;

c) Quản lý tập trung (cập nhật, cảnh báo và quản lý) các phần mềm phòng chống mã độc cài đặt trên máy chủ và các máy tính người sử dụng trong hệ thống;

- d) Có cơ chế kiểm tra, xử lý mã độc của các phương tiện lưu trữ di động trước khi kết nối với máy chủ;
- đ) Có cơ chế theo dõi, giám sát và cảnh báo khi có sự xuất hiện các tiến trình mới, các tập tin hệ thống trên máy chủ bị thay đổi.

Trích dẫn yêu cầu:

- Cài đặt phần mềm phòng chống mã độc, tự động cập nhật.
- Kiểm tra/dò quét phần mềm trước khi cài đặt.
- Quản lý tập trung phần mềm phòng chống mã độc.
- Kiểm tra mã độc trên phương tiện lưu trữ di động.
- Giám sát, cảnh báo tiến trình mới và file hệ thống bị thay đổi.

Giải thích yêu cầu: Yêu cầu bảo vệ máy chủ khỏi phần mềm độc hại tại tầng endpoint. Ngoài việc cài phần mềm anti-malware, còn yêu cầu giám sát hành vi (behavioral monitoring) để phát hiện malware chưa có signature. Quản lý tập trung giúp đảm bảo không có máy chủ nào bị bỏ sót.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Phần mềm anti-malware + auto update	Triển khai EDR/EPP (CrowdStrike Falcon, Kaspersky Endpoint Security, Symantec). Bật auto-update signature database.
2	Dò quét trước khi cài đặt	Mọi phần mềm trước khi cài phải được scan qua sandbox và anti-malware. Sử dụng software repository nội bộ đã được verify.
3	Quản lý tập trung	Sử dụng console quản lý tập trung (Kaspersky Security Center, Symantec SEPM, CrowdStrike Console). Dashboard giám sát trạng thái toàn bộ endpoint.
4	Kiểm tra USB/lưu trữ di động	Cấu hình Device Control: chặn USB mặc định, chỉ cho phép USB đã được whitelist. Bắt buộc scan toàn bộ USB trước khi truy cập dữ liệu.
5	Giám sát tiến trình & file integrity	Sử dụng EDR giám sát process tree, phát hiện tiến trình bất thường. Kết hợp AIDE/Tripwire giám sát thay đổi file hệ thống. Cảnh báo về SIEM.

9.2.2.6 Xử lý máy chủ khi chuyển giao

- a) Có biện pháp chuyên dụng để xóa sạch thông tin, dữ liệu trên máy chủ khi chuyển giao hoặc thay đổi mục đích sử dụng;
- b) Sao lưu dự phòng thông tin, dữ liệu trên máy chủ, bản dự phòng hệ điều hành máy chủ trước khi thực hiện xóa dữ liệu, hệ điều hành;
- c) Có biện pháp kiểm tra, bảo đảm dữ liệu không thể khôi phục sau khi xóa.

Trích dẫn yêu cầu:

- Có biện pháp chuyên dụng xóa sạch thông tin/dữ liệu khi chuyển giao hoặc thay đổi mục đích.
- Sao lưu dự phòng trước khi xóa.
- Bảo đảm dữ liệu không thể khôi phục sau khi xóa.

Giải thích yêu cầu: Khi máy chủ được chuyển giao, thanh lý hoặc thay đổi mục đích, dữ liệu cũ phải được xóa triệt để tránh rò rỉ thông tin. Với hệ thống cấp độ 5 (an ninh quốc gia), việc xóa phải sử dụng phương pháp chuyên dụng đảm bảo không thể khôi phục (data sanitization).

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Xóa sạch dữ liệu chuyên dụng	Sử dụng công cụ secure erase: DBAN (Darik's Boot and Nuke), shred (Linux), Blancco. Với SSD: sử dụng ATA Secure Erase hoặc Crypto Erase. Áp dụng tiêu chuẩn NIST SP 800-88 (Clear/Purge/Destroy).
2	Sao lưu trước khi xóa	Full backup máy chủ (OS image + data) lên hệ thống lưu trữ an toàn. Xác nhận backup integrity (checksum, test restore) trước khi tiến hành xóa.
3	Đảm bảo không khôi phục được	Với HDD: ghi đè nhiều lần (DoD 5220.22-M, 7 lần). Với SSD: Crypto Erase. Với dữ liệu tối mật: hủy vật lý ổ cứng (degaussing, shredding). Lập biên bản xác nhận việc xóa/hủy.

9.2.3 Bảo đảm an toàn ứng dụng

9.2.3.1 Xác thực

- a) Thiết lập cấu hình ứng dụng để xác thực người sử dụng khi truy cập, quản trị, cấu hình ứng dụng;
- b) Lưu trữ có mã hóa thông tin xác thực hệ thống;
- c) Thiết lập cấu hình ứng dụng để đảm bảo an toàn mật khẩu người sử dụng, bao gồm các yêu cầu sau:
- Yêu cầu thay đổi mật khẩu mặc định;
 - Thiết lập quy tắc đặt mật khẩu về số ký tự, loại ký tự;
 - Thiết lập thời gian yêu cầu thay đổi mật khẩu;
 - Thiết lập thời gian mật khẩu hợp lệ.
- d) Hạn chế số lần đăng nhập sai trong khoảng thời gian nhất định với tài khoản nhất định;
- đ) Mã hóa thông tin xác thực trước khi gửi qua môi trường mạng;
- e) Thiết lập cấu hình ứng dụng để ngăn cản việc đăng nhập tự động đối với các ứng dụng, dịch vụ cung cấp và xử lý dữ liệu quan trọng trong hệ thống;
- g) Vô hiệu hóa tài khoản nếu đăng nhập sai nhiều lần vượt số lần quy định;

h) Sử dụng cơ chế xác thực đa nhân tố để xác thực người sử dụng khi truy cập, quản trị các dịch vụ quan trọng trong hệ thống.

Trích dẫn yêu cầu: Xác thực người dùng khi truy cập/quản trị ứng dụng; mã hóa thông tin xác thực lưu trữ; chính sách mật khẩu (thay đổi mặc định, quy tắc, thời hạn); hạn chế đăng nhập sai; mã hóa thông tin xác thực qua mạng; ngăn đăng nhập tự động; vô hiệu hóa tài khoản sai nhiều lần; MFA cho dịch vụ quan trọng.

Giải thích yêu cầu: Thiết lập xác thực mạnh mẽ ở tầng ứng dụng, bao gồm MFA bắt buộc cho dịch vụ quan trọng, chống brute-force, bảo vệ credential cả khi lưu trữ (at-rest) và truyền tải (in-transit).

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Xác thực người dùng	Tích hợp SSO qua Keycloak/ADFS. Bắt buộc đăng nhập cho mọi chức năng.
2	Mã hóa credential lưu trữ	Hash mật khẩu bằng bcrypt/Argon2. Không dùng MD5/SHA1.
3	Chính sách mật khẩu	Cấu hình ứng dụng: ≥12 ký tự, hỗn hợp loại ký tự, đổi mỗi 90 ngày, không tái sử dụng 12 mật khẩu gần nhất.
4	Hạn chế đăng nhập sai & khóa tài khoản	Rate limiting login API (5 lần/15 phút). Tự động khóa tài khoản + CAPTCHA sau ngưỡng.
5	Mã hóa credential trên mạng	Bắt buộc HTTPS/TLS 1.2+. Không truyền mật khẩu dạng plaintext.
6	Ngăn đăng nhập tự động	Disable "Remember Me" cho ứng dụng quan trọng. Không lưu credential trong cookie/localStorage.
7	MFA cho dịch vụ quan trọng	Tích hợp TOTP (Google Authenticator), hardware token (YubiKey), hoặc SMS OTP cho admin panel và dịch vụ nhạy cảm.

9.2.3.2 Kiểm soát truy cập

- a) Thiết lập hệ thống chỉ cho phép sử dụng các kết nối mạng an toàn khi truy cập, quản trị ứng dụng từ xa;
- b) Thiết lập giới hạn thời gian chờ (timeout) để đóng phiên kết nối khi ứng dụng không nhận được yêu cầu từ người dùng;
- c) Giới hạn địa chỉ mạng quản trị được phép truy cập, quản trị ứng dụng từ xa;
- d) Phân quyền truy cập, quản trị, sử dụng tài nguyên khác nhau của ứng dụng với người sử dụng/ nhóm người sử dụng có chức năng, yêu cầu nghiệp vụ khác nhau;
- đ) Giới hạn số lượng các kết nối đồng thời (kết nối khởi tạo và đã thiết lập) đối với các ứng dụng, dịch vụ máy chủ cung cấp;

- e) Cấp quyền tối thiểu (quyền truy cập, quản trị) cho tài khoản quản trị ứng dụng theo quyền hạn;
- g) Thiết lập quyền tối thiểu (chỉ cấp quyền truy cập cơ sở dữ liệu) cho tài khoản kết nối cơ sở dữ liệu;
- h) Thay đổi, tách biệt cổng quản trị ứng dụng với cổng cung cấp dịch vụ ứng dụng;
- i) Khóa tạm thời hoặc không cho phép quản trị ứng dụng trong khoảng thời gian ngoài giờ làm việc theo chính sách của tổ chức (nếu có).

Trích dẫn yêu cầu: Kết nối an toàn khi quản trị từ xa; timeout phiên; giới hạn IP quản trị; phân quyền RBAC; giới hạn kết nối đồng thời; quyền tối thiểu cho admin và DB account; tách cổng quản trị/dịch vụ; khóa quản trị ngoài giờ.

Giải thích yêu cầu: Kiểm soát toàn diện truy cập ứng dụng theo nguyên tắc least privilege, tách biệt quản trị và dịch vụ, giới hạn bề mặt tấn công từ cả bên trong lẫn bên ngoài.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Kết nối an toàn	HTTPS/TLS 1.2+ bắt buộc. Redirect HTTP→HTTPS. HSTS header.
2	Timeout phiên	Session timeout 15-30 phút idle. Absolute timeout 8 giờ.
3	Giới hạn IP quản trị	Whitelist IP/subnet quản trị trên WAF/reverse proxy. Admin panel chỉ truy cập từ vùng quản trị.
4	Phân quyền RBAC	Triển khai RBAC trong ứng dụng. Tách role: viewer, editor, admin, super-admin.
5	Giới hạn kết nối đồng thời	Cấu hình max connections trên web server (Nginx worker_connections) và application server. Rate limiting trên API Gateway.
6	Quyền tối thiểu DB	Tài khoản ứng dụng kết nối DB chỉ có quyền SELECT/INSERT/UPDATE trên bảng cần thiết. Không cấp DBA/DDL.
7	Tách cổng quản trị/dịch vụ	Admin panel chạy port riêng (VD: 8443) hoặc subdomain riêng, chỉ mở từ vùng quản trị.
8	Khóa quản trị ngoài giờ	Middleware kiểm tra thời gian truy cập admin. Cấu hình WAF rule chặn admin URL ngoài giờ hành chính.

9.2.3.3 Nhật ký hệ thống

a) Ghi nhật ký hệ thống bao gồm những thông tin cơ bản sau:

- Thông tin truy cập ứng dụng;
- Thông tin đăng nhập khi quản trị ứng dụng;
- Thông tin các lỗi phát sinh trong quá trình hoạt động;
- Thông tin thay đổi cấu hình ứng dụng.

- b) Quản lý và lưu trữ nhật ký hệ thống trên hệ thống quản lý tập trung;
- c) Nhật ký hệ thống phải được lưu trữ trong khoảng thời gian tối thiểu là 12 tháng;
- d) Lưu trữ dự phòng dữ liệu nhật ký hệ thống trên hệ thống lưu trữ riêng biệt, có mã hóa với những dữ liệu nhật ký quan trọng (nếu có);
- d) Phân quyền truy cập, quản lý dữ liệu nhật ký hệ thống đối với các tài khoản có chức năng quản trị hệ thống khác nhau.

Trích dẫn yêu cầu: Ghi nhật ký: truy cập ứng dụng, đăng nhập quản trị, lỗi, thay đổi cấu hình. Lưu trữ tập trung, ≥12 tháng, dự phòng mã hóa, phân quyền truy cập log.

Giải thích yêu cầu: Nhật ký ứng dụng ghi lại mọi hành động nghiệp vụ và quản trị, phục vụ audit trail, forensics và phát hiện hành vi bất thường ở tầng ứng dụng.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Ghi nhật ký ứng dụng	Sử dụng structured logging (JSON format) với framework (Log4j2, Serilog, Winston). Ghi: user, action, timestamp, IP, result.
2	Lưu trữ tập trung	Ship log qua Filebeat/Fluentd về ELK Stack hoặc SIEM. Tách log ứng dụng khỏi log hệ thống.
3	Lưu ≥12 tháng	Index lifecycle management trên Elasticsearch. Hot→Warm→Cold→Archive.
4	Dự phòng & mã hóa	Replicate log index sang cluster phụ. Mã hóa log nhạy cảm bằng AES-256.
5	Phân quyền	RBAC trên Kibana/SIEM: dev chỉ xem log lỗi, security analyst xem audit log, admin full access.

9.2.3.4 Bảo mật thông tin liên lạc

- a) Mã hóa thông tin, dữ liệu (không phải là thông tin, dữ liệu công khai) trước khi truyền đưa, trao đổi qua môi trường mạng; sử dụng phương án mã hóa theo quy định về bảo vệ bí mật nhà nước đối với thông tin mật;
- b) Sử dụng kết nối mạng an toàn, bảo đảm an toàn trong quá trình khởi tạo kết nối kênh truyền và trao đổi thông tin qua kênh truyền;
- c) Sử dụng kết hợp các kết nối mạng an toàn hoặc biện pháp mã hóa để bảo đảm dữ liệu quan trọng được mã hóa 02 lần khi truyền qua môi trường mạng;
- d) Sử dụng kênh vật lý riêng khi truyền đưa, trao đổi qua môi trường mạng đối với dữ liệu quan trọng;
- d) Sử dụng thiết bị, phương tiện chuyên dụng để phục vụ mã hóa và giải mã.

Trích dẫn yêu cầu: Mã hóa dữ liệu không công khai khi truyền qua mạng; kết nối mạng an toàn; dữ liệu quan trọng mã hóa 2 lần; kênh vật lý riêng cho dữ liệu quan trọng; thiết bị chuyên dụng mã hóa/giải mã.

Giải thích yêu cầu: Bảo vệ tính bí mật của dữ liệu trong quá trình truyền tải. Ở cấp độ 5, yêu cầu mã hóa 2 lần (double encryption) và kênh vật lý riêng cho dữ liệu tối mật, kết hợp thiết bị chuyên dụng (HSM).

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Mã hóa dữ liệu truyền tải	Bắt buộc TLS 1.2/1.3 cho mọi kết nối. Mã hóa theo quy định bảo vệ bí mật nhà nước (thuật toán được Ban Cơ yếu Chính phủ phê duyệt).
2	Kết nối mạng an toàn	VPN IPSec/SSL cho kết nối liên site. Certificate pinning cho ứng dụng. Perfect Forward Secrecy (PFS).
3	Mã hóa 2 lần	Lớp 1: TLS kênh truyền. Lớp 2: Application-level encryption (AES-256) cho payload dữ liệu quan trọng trước khi gửi qua TLS.
4	Kênh vật lý riêng	Sử dụng leased-line/MPLS riêng biệt cho dữ liệu tối mật. Không chia sẻ đường truyền với dữ liệu thông thường.
5	Thiết bị mã hóa chuyên dụng	Triển khai HSM (Hardware Security Module: Thales Luna, nCipher). Sử dụng máy mã chuyên dụng do Ban Cơ yếu Chính phủ cung cấp.

9.2.3.5 Chống chối bỏ

a) Sử dụng chữ ký số khi trao đổi thông tin, dữ liệu quan trọng;

b) Chữ ký số được cung cấp bởi cơ quan có thẩm quyền hoặc đơn vị cung cấp dịch vụ chữ ký số được cấp phép;

c) Có phương án bảo đảm an toàn trong việc quản lý và sử dụng chữ ký số;

d) Sử dụng thiết bị, phương tiện chuyên dụng để thực hiện ký và giải mã thông tin, dữ liệu khi gửi và nhận.

Trích dẫn yêu cầu: Sử dụng chữ ký số cho dữ liệu quan trọng; chữ ký số từ cơ quan có thẩm quyền; phương án an toàn quản lý chữ ký số; thiết bị chuyên dụng ký và giải mã.

Giải thích yêu cầu: Đảm bảo tính chống chối bỏ (non-repudiation) — người gửi không thể phủ nhận việc đã gửi thông tin. Chữ ký số là bằng chứng pháp lý về nguồn gốc và tính nguyên vẹn của dữ liệu.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Chữ ký số cho dữ liệu quan trọng	Tích hợp chữ ký số vào quy trình phê duyệt văn bản, trao đổi dữ liệu. Sử dụng PKI (Public Key Infrastructure).
2	Chữ ký số từ cơ quan có thẩm quyền	Sử dụng chứng thư số do CA được cấp phép (VNPT-CA, Viettel-CA, FPT-CA hoặc Ban Cơ yếu Chính phủ).

#	Yêu cầu	Giải pháp
3	An toàn quản lý chữ ký số	Lưu khóa bí mật trên USB Token/Smart Card. Chính sách quản lý vòng đời chứng thư (cấp phát, gia hạn, thu hồi).
4	Thiết bị chuyên dụng ký/giải mã	Sử dụng HSM cho việc ký số và giải mã phía server. USB Token chuyên dụng cho người dùng cuối.

9.2.3.6 An toàn ứng dụng và mã nguồn

- a) Có chức năng kiểm tra tính hợp lệ của thông tin, dữ liệu đầu vào trước khi xử lý;
- b) Có chức năng kiểm tra tính hợp lệ của thông tin, dữ liệu đầu ra trước khi gửi về máy yêu cầu;
- c) Có phương án bảo vệ ứng dụng chống lại những dạng tấn công phổ biến: SQL Injection, OS command injection, RFI, LFI, Xpath injection, XSS, CSRF;
- d) Có chức năng kiểm soát lỗi, thông báo lỗi từ ứng dụng;
- đ) Không lưu trữ thông tin xác thực, thông tin bí mật trên mã nguồn ứng dụng;
- e) Có chức năng tạo lập, duy trì và quản lý phiên làm việc an toàn.

Trích dẫn yêu cầu: Kiểm tra dữ liệu đầu vào/đầu ra; chống tấn công phổ biến (SQLi, XSS, CSRF, RFI, LFI, Command Injection, Xpath Injection); kiểm soát lỗi; không lưu credential trong mã nguồn; quản lý phiên làm việc an toàn.

Giải thích yêu cầu: Bảo vệ ứng dụng khỏi các lỗ hổng bảo mật phổ biến theo OWASP Top 10. Đây là lớp bảo vệ ở tầng code/logic, yêu cầu secure coding practices và kiểm thử an toàn.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Kiểm tra đầu vào	Input validation (whitelist), sanitization, parameterized queries. Sử dụng framework validation (Joi, FluentValidation).
2	Kiểm tra đầu ra	Output encoding (HTML entity, URL encoding). Content-Type header chính xác. X-Content-Type-Options: nosniff.
3	Chống tấn công phổ biến	WAF (ModSecurity, Cloudflare WAF). Parameterized queries (chống SQLi). CSRF token. CSP header (chống XSS). Không dùng eval/include động (chống RFI/LFI).
4	Kiểm soát lỗi	Custom error pages (không lộ stack trace, version). Centralized exception handling. Log lỗi chi tiết nhưng chỉ trả về thông báo chung cho người dùng.
5	Không lưu secret trong code	Sử dụng Secret Manager (HashiCorp Vault, AWS Secrets Manager). Biến môi trường hoặc config file ngoài source code. Git pre-commit hook kiểm tra secret leak.

#	Yêu cầu	Giải pháp
6	Quản lý phiên an toàn	Session ID ngẫu nhiên, entropy cao. HttpOnly + Secure + SameSite cookie. Regenerate session ID sau login. Invalidate session khi logout.

9.2.4 Bảo đảm an toàn dữ liệu

9.2.4.1 Nguyên vẹn dữ liệu

- a) Có phương án chuyên dụng để quản lý, lưu trữ dữ liệu trong hệ thống bảo đảm tính nguyên vẹn;
- b) Có phương án giám sát, cảnh báo khi có thay đổi thông tin, dữ liệu lưu trên hệ thống lưu trữ/phương tiện lưu trữ;
- c) Có phương án khôi phục tính nguyên vẹn của thông tin dữ liệu.

Trích dẫn yêu cầu: Phương án chuyên dụng quản lý/lưu trữ dữ liệu đảm bảo nguyên vẹn; giám sát/cảnh báo khi dữ liệu bị thay đổi; phương án khôi phục tính nguyên vẹn.

Giải thích yêu cầu: Đảm bảo dữ liệu không bị sửa đổi trái phép (integrity). Phát hiện sớm mọi thay đổi và có khả năng khôi phục về trạng thái nguyên vẹn khi bị compromise.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Quản lý dữ liệu nguyên vẹn	Sử dụng checksum/hash (SHA-256) cho file quan trọng. RAID 5/6/10 cho storage. Database integrity constraints. ZFS/Btrfs với data checksumming.
2	Giám sát thay đổi dữ liệu	Triển khai File Integrity Monitoring (AIDE, Tripwire, OSSEC). Database Activity Monitoring (DAM). Cảnh báo real-time về SIEM khi phát hiện thay đổi.
3	Khôi phục nguyên vẹn	Backup định kỳ (daily incremental, weekly full). Database point-in-time recovery (WAL/binlog). Version control cho cấu hình. Định kỳ kiểm tra backup restore.

9.2.4.2 Bảo mật dữ liệu

- a) Lưu trữ có mã hóa các thông tin, dữ liệu (không phải là thông tin, dữ liệu công khai) trên hệ thống lưu trữ/phương tiện lưu trữ;
- b) Sử dụng các phương pháp mã hóa mạnh (chưa được các tổ chức quốc tế công bố điểm yếu an toàn thông tin) để mã hóa dữ liệu;
- c) Có phương án chuyên dụng để quản lý và bảo vệ dữ liệu mã hóa và khóa giải mã;

d) Thiết lập phân vùng lưu trữ mã hóa, phân quyền truy cập chỉ cho phép người có quyền được truy cập, quản lý dữ liệu mã hóa.

Trích dẫn yêu cầu: Mã hóa dữ liệu không công khai khi lưu trữ; dùng phương pháp mã hóa mạnh (chưa có điểm yếu được công bố); phương án chuyên dụng quản lý dữ liệu mã hóa và khóa; phân vùng lưu trữ mã hóa và phân quyền.

Giải thích yêu cầu: Bảo vệ tính bí mật của dữ liệu tại trạng thái nghỉ (at-rest). Ngay cả khi phương tiện lưu trữ bị đánh cắp vật lý, dữ liệu vẫn không đọc được nếu không có khóa giải mã.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Mã hóa dữ liệu lưu trữ	Transparent Data Encryption (TDE) cho database. LUKS/dm-crypt (Linux), BitLocker (Windows) cho ổ đĩa. Mã hóa column-level cho dữ liệu nhạy cảm trong DB.
2	Phương pháp mã hóa mạnh	Sử dụng AES-256, RSA-2048+. Không dùng DES, 3DES, RC4. Tuân thủ quy định của Ban Cơ yếu Chính phủ cho thông tin mật.
3	Quản lý khóa chuyên dụng	Sử dụng HSM lưu trữ Master Key. Key Management System (KMS) tập trung. Key rotation định kỳ. Tách biệt người quản lý khóa và người quản lý dữ liệu.
4	Phân vùng mã hóa & phân quyền	Tạo encrypted volume riêng cho dữ liệu mật. RBAC truy cập dữ liệu mã hóa. Audit log mọi lần truy cập/giải mã.

9.2.4.3 Sao lưu dữ liệu

- a) Thực hiện sao lưu dự phòng các thông tin, dữ liệu cơ bản sau: tập tin cấu hình hệ thống, bản dự phòng hệ điều hành máy chủ, cơ sở dữ liệu; dữ liệu, thông tin nghiệp vụ;
- b) Phân loại và quản lý các dữ liệu được lưu trữ theo từng loại/nhóm thông tin được gán nhãn khác nhau;
- c) Có hệ thống/phương tiện lưu trữ độc lập để sao lưu dự phòng;
- d) Phương án sao lưu dự phòng có tính sẵn sàng cao, cho phép khôi phục dữ liệu nóng khi một thành phần trong hệ thống xảy ra sự cố;
- đ) Lưu trữ dự phòng các dữ liệu quan trọng trên hệ thống/phương tiện lưu trữ dự phòng ở vị trí địa lý khác nhau; bảo đảm môi trường bảo quản và phương pháp quản lý giống như với hệ thống chính;
- e) Duy trì ít nhất 02 kết nối mạng từ hệ thống sao lưu dự phòng chính với hệ thống sao lưu dự phòng phụ.

Trích dẫn yêu cầu: Sao lưu cấu hình, OS, CSDL, dữ liệu nghiệp vụ; phân loại/gán nhãn dữ liệu; hệ thống lưu trữ độc lập; tính sẵn sàng cao, khôi phục nóng; dự phòng ở vị trí địa lý khác; duy trì ≥2 kết nối mạng giữa hệ thống backup chính và phụ.

Giải thích yêu cầu: Đảm bảo khả năng khôi phục dữ liệu trong mọi tình huống (sự cố, thảm họa). Với cấp độ 5, yêu cầu khôi phục nóng (zero/near-zero downtime) và dự phòng địa lý với độ tin cậy cao nhất.

Giải pháp đáp ứng yêu cầu:

#	Yêu cầu	Giải pháp
1	Sao lưu cấu hình, OS, DB, dữ liệu	Triển khai backup tập trung (Veeam, Commvault). Chính sách: daily incremental + weekly full. Sao lưu cấu hình thiết bị vào Git/TFVC.
2	Phân loại & gán nhãn dữ liệu	Phân loại: Tối mật, Bí mật, Nội bộ, Công khai. Gán nhãn metadata trên hệ thống backup. Chính sách retention khác nhau cho từng loại.
3	Hệ thống lưu trữ độc lập	NAS/SAN chuyên dụng cho backup, tách biệt với storage production. Tape library cho long-term archive.
4	Sẵn sàng cao, khôi phục nóng	Database replication (MySQL Group Replication, PostgreSQL Streaming Replication). Storage-level replication (SAN mirroring). RPO ≈ 0, RTO < 15 phút.
5	Dự phòng địa lý khác	DR site cách ≥30km. Đồng bộ dữ liệu near real-time. Môi trường bảo quản đạt chuẩn (nhiệt độ, độ ẩm, PCCC). Định kỳ diễn tập DR switchover.
6	≥2 kết nối mạng giữa backup chính và phụ	Thuê ≥2 đường truyền từ nhà cung cấp khác nhau (leased-line/MPLS). Cấu hình failover tự động. Mã hóa dữ liệu replication qua kênh truyền.